



Sikkerhedsbrud, konsekvensanalyser, datatilsyn mv.

4. Forelæsning



AALBORG
UNIVERSITET



Dagens program

- › Fortegnelser
- › Privacy by design
- › Behandlingssikkerhed
- › Konsekvensanalyser
- › Sikkerhedsbrud
- › DPO
- › Datatilsynet
- › Danske bøder

Artikel 30 fortegnelse

Fortegnelse over behandlingsaktiviteter

- ▶ Formål med fortegnelse
 - ▶ Dokumentere overholdelse af GDPR (ansvarlighed)
 - ▶ Internt overblik over behandlingsaktiviteter
 - ▶ Grundlag for videre compliancearbejde
- ▶ Formkrav til fortegnelsen
 - ▶ Skriftlig og elektronisk
 - ▶ Skema eller Word-dokument
 - ▶ Opdateres løbende
 - ▶ Udleveres til Datatilsynets efter anmodning.



Indholds krav



► Den dataansvarlige

- › Kontaktoplysninger for den dataansvarlige
- › Formål med behandlingen
- › Kategori af registrerede og personoplysninger
- › Kategori af modtagere
- › Evt. tredjelandsoverførsler
- › Tidsfrist for sletning pr. kategori af personoplysning
- › Generel beskrivelse af sikkerhedsforanstaltninger

► Databehandler

- › Kontaktoplysninger for databehandler og hver dataansvarlige
- › Kategori af behandling
- › Evt. tredjelandsoverførsler
- › Generel beskrivelse af sikkerhedsforanstaltninger

Hvornår fortegnelse

6



HR: alle virksomheder og myndigheder



U: Privatvirksomhed beskæftiger under 250 personer



UU1: Vil behandlingen medføre risiko for den registreredes rettigheder



UU2: Er behandlingen lejlighedsvis



UU3: Omfatter behandlingen følsomme personoplysninger eller oplysninger om strafbare forhold?

Databeskyttelse gennem design og standardindstillinger

GDPR art. 25

- ordlyden

Artikel 25 Databeskyttelse gennem design og databeskyttelse gennem standardindstillinger

- 1. Under hensyntagen til det aktuelle tekniske niveau, implementeringsomkostningerne og den pågældende behandlings karakter, omfang, sammenhæng og formål samt risiciene af varierende sandsynlighed og alvor for fysiske personers rettigheder og frihedsrettigheder, som behandlingen indebærer, gennemfører den dataansvarlige både på tidspunktet for fastlæggelse af midlerne til behandling og på tidspunktet for selve behandlingen passende tekniske og organisatoriske foranstaltninger, såsom pseudonymisering, som er designet med henblik på effektiv implementering af databeskyttelsesprincipper, såsom dataminimering, og med henblik på integrering af de fornødne garantier i behandlingen for at opfylde kravene i denne forordning og beskytte de registreredes rettigheder.
- 2. Den dataansvarlige gennemfører passende tekniske og organisatoriske foranstaltninger med henblik på gennem standardindstillinger at sikre, at kun personoplysninger, der er nødvendige til hvert specifikt formål med behandlingen, behandles. Denne forpligtelse gælder den mængde personoplysninger, der indsamles, og omfanget af deres behandling samt deres opbevaringsperiode og tilgængelighed. Sådanne foranstaltninger skal navnlig gennem standardindstillinger sikre, at personoplysninger ikke uden den pågældende fysiske persons indgriben stilles til rådighed for et ubegrænset antal fysiske personer.
- 3. En godkendt certificeringsmekanisme i medfør af artikel 42 kan blive brugt som et element til at påvise overholdelse af kravene i nærværende artikels stk. 1 og 2

7 principper for privacy by design

1. Proaktiv, ikke reaktiv

- Forvent og forhindre privatlivs problemer før de opstår
- Udarbejd systemer der modvirker potentielle sikkerhedsbrud
- Opbyg tillid ved at være proaktiv

2. Privatliv som standardindstilling

- Privatlivsbeskyttelse skal være automatisk slået til
- Brugernes personoplysninger skal være private uden at de selv skal gøre noget
- Privatliv skal være standardnormen

3. Privatliv skal være integreret i designet

- Udvikl systemer med privatliv fra bunden og op
- Privatliv skal ikke være en eftertanke men en kernefunktion
- Tænk på det som når du rører et hus

4. Fuld funktionalitet – positivt og ikke nulsum

- Opnå en win-win: Privatliv og funktionalitet
- Ingen byttehandler eller kompromiser
- Giv servicen og respekter privatliv

5. End-to-end sikkerhed – livscyklus beskyttelse

- Data skal være sikker fra indsamling til sletning
- Enhver behandling skal være sikker, både opbevaring, brug og sletning
- Hav sikker datamanagement hele vejen

6. Synlighed og gennemsigtighed

- Operer åbent og sandt
- Udarbejd synlige og forståelige sikkerhedspolitikker
- Gennemsigtighed medfører tillid

7. respekter brugernes privatliv

- Sæt brugerne og deres privatliv først
- Behandl personoplysninger som en personlig dagbog – det er deres ikke dine
- Hjælp brugerne med at sikre kontrol over deres personoplysninger

Aktuelle tekniske niveau?

Ikke et fast niveau, men en løbende vurdering af, hvad der beskytter personoplysninger effektivt nu.

1 FØLG UDVIKLINGEN — Kend markedet

Hold jer ajour med nye teknologier – og de risici og muligheder, de skaber.

2 OMKOSTNINGER TIL IVÆRKSÆTTELSEN — ressourcer (også menneskelig og tid)

Omkostninger til iværksættelse er en faktor, der skal tages i betragtning ved gennemførelse af databeskyttelse gennem design, men ikke som en grund til at undlade at gennemføre dem

3 VURDÉR IGEN — Det passende ændrer sig

En løsning, der var tilstrækkelig i går, kan være utilstrækkelig i morgen.

PRAKTISK PEJLEMÆRKE

Brug anerkendte standarder, certificeringer og kodekser som pejlemærker – og dokumentér, hvornår vurderingen skal gentages.

Privacy by default

- Privacy by default er en præcisering af princippet om data-minimering (GDPR art. 5, stk. 1, litra c)
 - Standardindstillinger skal begrænses til det, der er nødvendigt for at opfylde formålet
 - Fokus er på mængden af personoplysninger, omfang af behandling, opbevaringsperiode og tilgængelighed
 - Standardindstillinger skal forstås bredt (både tekniske og organisatoriske foranstaltninger)
 - Privacy by default handler ikke om de øvrige principper



Datatilsynets praksis

- Hvad er problemet?
- <https://www.datatilsynet.dk/afgoerelser/afgoerelser/2024/sep/alvorlig-kritik-paabud-og-advarsel-i-sag-om-pant-app>
- Læs kun afsnit 3.4

Pant-app får alvorlig kritik for GDPR-brud

8. oktober 2024 kl. 17.36 | **Bemærk:** Artiklen er mere end 30 dage gammel

Datatilsynets kontrol af appen "Pant" fra Dansk Retursystem har ført til alvorlig kritik for ikke at leve op til GDPR-reglerne om behandling af personoplysninger. Det skriver Datatilsynet i en pressemeddelelse.

En undersøgelse har vist, at appen ikke kun indhenter brugerens kontooplysninger, men også oplysninger om brugerens saldi, identitetsoplysninger og transaktionshistorik. Dansk Retursystem har fået påbud om rette op på håndteringen af personoplysninger inden 2. januar 2025.

Af Kamilla Sørensen



(Foto: Datatilsynet)

Ny afgørelse fra Datatilsynet: Eksterne komponenter i danske apps kan være i strid med GDPR

Det kan være i strid med GDPR, hvis du står bag en app, der anvender API'er og eksterne komponenter fra eksterne parter, viser ny afgørelse fra Datatilsynet. Og du har ansvaret.

7. oktober 2024 kl. 16.47



QENDRIM
FAZLIU
Samfunds- og debatredaktør

Datatilsynet har afgjort en sag mod Dansk Retursystems "Pant"-app og udtaler alvorlig kritik for manglende overholdelse af GDPR-reglerne.

Behandlingssikkerhed

Passende sikkerhedsniveau

- GDPR art. 25 kræver passende sikkerhedsniveau, som beror på en konkret risikovurdering
- Den dataansvarlige og databehandleren skal foretage risikovurderinger
- Risikovurderinger dokumenterer passende sikkerhedsniveau
- De registrerede er centrum for risikovurderingen
- Risikovurderinger hjælper med at vurdere, om personoplysninger beskyttes tilstrækkeligt

Hvornår skal der risikovurderes?

Foretages eller genbesøges

- Nye behandlingsaktiviteter
- Nyt system eller app
- Anvender ny leverandør
- Kontrol af databehandler
- Udarbejdelse af konsekvensanalyse(DPIA)
- Overførsel til tredjelande (TIA)

Datatilsynets tilgang ved risikovurdering



Vurdering af sårbarhed

Tekniske foranstaltninger

- Adgangskontrol
- Anonymisering
- Antispam og antiphishing filtre
- Antivirus
- Asset management / styring af udstyr på netværket
- Backup og reetablering
- Sikkerhed

Organisatoriske foranstaltninger

- Beredskabsplan
- Fortegnelse
- HR-instruks
- IT-sikkerhedspolitik
- Privatlivspolitikker
- Procedurer for håndtering af sikkerhedsbrud
- Træning af medarbejdere

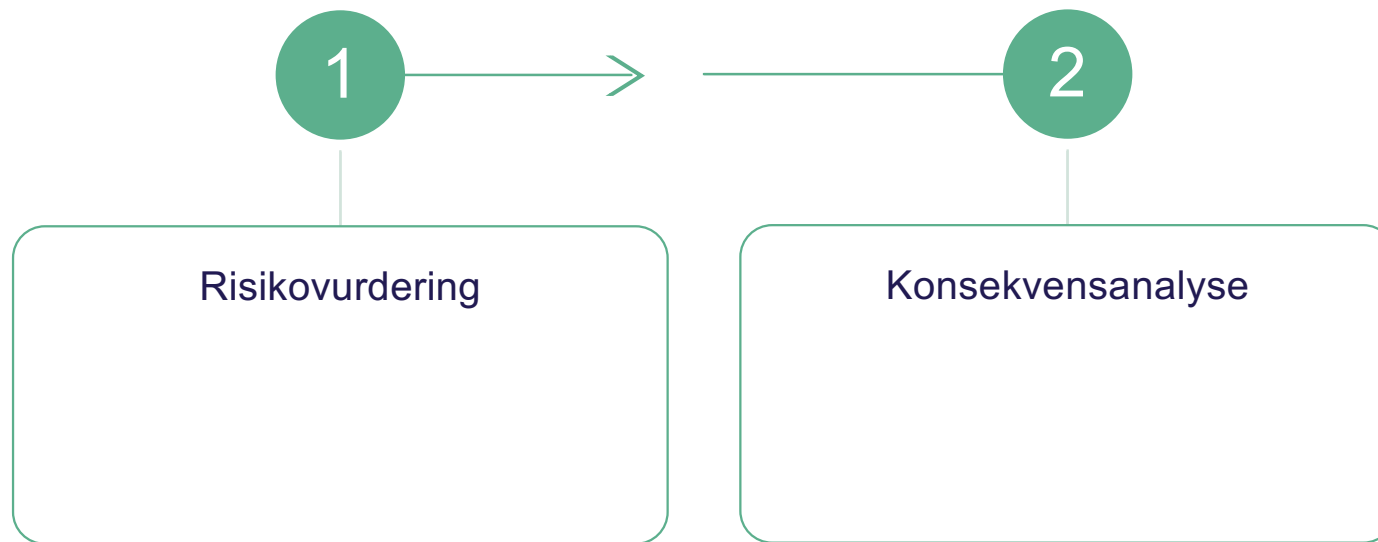


Risikomatrix				
Ødelæggende (4)	Høj	Meget høj	Meget høj	Meget høj
Meget alvorlig (3)	Mellem	Høj	Høj	Meget høj
Mindre alvorlig (2)	Lav	Mellem	Høj	Høj
Ubetydelig (1)	Lav	Lav	Mellem	Høj
	Usandsynligt (1)	Mindre sandsynligt (2)	Sandsynligt (3)	Forventet (4)

Risikovurdering

**Konsekvensanalyse
artikel 35 og 36**

Først risikovurdering, så konsekvensanalyse



Konsekvensanalyse vedrørende databeskyttelse



KONSEKVENSANALYSE VEDRØRENDE DATABESKYTTELSE

En konsekvensanalyse er et krav efter databeskyttelsesreglerne. Analysen er et værktøj, som gør det muligt at arbejde med de risici, som en behandlingsaktivitet kan indebære, på en systematisk måde.

Analysen skal gennemføres, hvis en behandlingsaktivitet sandsynligvis vil indebære høje risici for de registrerede.

Reglerne om konsekvensanalyse og eventuel høring af Datatilsynet skal sikre, at ingen behandling, hvor der er en løbende høj risiko, igangsættes, uden man har arbejdet med og nedbragt sådanne risici.

HVORDAN GENNEMFØRES ANALYSEN?

En analyse bør iværksættes tidligt i et projektforsøg, og inden en behandlingsaktivitet iværksættes. Analysen bør ske sideløbende med projektforsøget og omfatte følgende:

- 1) Vurdering af, om en konsekvensanalyse er nødvendig
- 2) Beskrivelse af behandlingsaktiviteten
- 3) Vurdering af lovlighed
- 4) Identifikation og vurdering af risici
- 5) Identifikation og implementering af relevante mitigerende foranstaltninger
- 6) Rådgørelse med relevante interessenter
- 7) Planlægning af, hvornår og hvordan relevante foranstaltninger implementeres
- 8) Regelmæssig ajourføring

TJEKLISTE TIL KVALITETSSIKRING

- ☐ Behandlingsaktivitet, samt hvorfor det er nødvendigt at gennemføre en konsekvensanalyse, er beskrevet
- ☐ Dokumentet er struktureret logisk og systematisk
- ☐ Konsekvensanalysen er skrevet i klart og tilgængeligt sprog, og eventuelle tekniske termer og forkortelser, der er blevet brugt, er beskrevet
- ☐ Rollefordelingen mellem de involverede aktører er klart beskrevet. Det samme er datastrømme og den tekniske understøttelse af løsningen, herunder ved brug af diagrammer og bilag om nødvendigt
- ☐ Datastrømmene mellem systemer, personer, organisationer og eventuelt lande er klart og tydeligt beskrevet
- ☐ Det er klart beskrevet, hvordan overholdelse af databeskyttelsesreglerne sikres
- ☐ Det er klart beskrevet, hvordan de registreredes rettigheder kan iagttages
- ☐ Alle relevante risici for de registreredes rettigheder og frihedsrettigheder er identificeret. Risicienes sandsynlighed og alvor er vurderet, og alle relevante mitigerende foranstaltninger er beskrevet
- ☐ Det er klart beskrevet, hvordan de påtænkte foranstaltninger konkret mitigerer de identificerede risici
- ☐ Den eventuelle interessentinddragelse er beskrevet
- ☐ Overholdelse af eventuelle godkendte adfærdskodekser er inddraget
- ☐ Relevante bilag, f.eks. privatspøispolitikker, dokumentation vedrørende databehandlere, dokumentation vedrørende behandlingsikkerhed mv., er vedlagt
- ☐ Høring af Datatilsynet, hvis der har vist sig at være høje risici som ikke kunne mitigeres, er foretaget
- ☐ Der er lagt en plan for, hvornår og hvordan de relevante mitigerende foranstaltninger implementeres
- ☐ Konsekvensanalysen er blevet forelagt ledelsen, og ledelsen har godkendt analysen
- ☐ En passende periode for at genbesøge, og om nødvendigt ajourføre analysen, er fastlagt



Hvad er en konsekvensanalyse, og hvornår er den relevant?

- Konsekvensanalysen er et krav efter databeskyttelsesreglerne. Analysen er et værktøj, som gør det muligt at arbejde med de risici, som en behandlingsaktivitet kan indebære, på en systematisk måde. Analysen skal gennemføres, hvis en behandlingsaktivitet sandsynligvis vil indebære høje risici for de registrerede.

<https://www.datatilsynet.dk/presse-og-nyheder/nyhedsarkiv/2024/maj/nye-skabeloner-til-gennemfoerelse-af-konsekvensanalyser>

Konsekvensanalyse

GDRP art. 35 og 36

22



HR:	Behandlingen sandsynligvis vil indebære en <u>høj risiko</u> for fysiske personers rettigheder og frihedsrettigheder.
Tidspunkt:	Forud for behandlingens opstart.

Typetilfælde

23

Situationer, hvor der altid skal udarbejde konsekvensanalyser:

Datatilsynet har udarbejdet et udkast til en liste, der er blevet godkendt af EDPB; Disse behandlingsaktiviteter vil sandsynligvis altid indebære en høj risiko for fysiske personers rettigheder og frihedsrettigheder, og der skal derfor udarbejdes en DPIA:

1. Behandling af biometriske data med det formål entydigt at identificere en fysisk person i sammenhæng med mindst et yderligere kriterie fra Artikel 29-gruppens retningslinjer (WP248 rev. 01).
2. Behandling af genetiske data i sammenhæng med mindst et yderligere kriterie fra Artikel 29- gruppens retningslinjer (WP248 rev. 01).
3. Behandling af lokationsdata i sammenhæng med mindst et yderligere kriterie fra Artikel 29- gruppens retningslinjer (WP248 rev. 01).
4. Behandling ved brug af nye teknologier i sammenhæng med mindst et yderligere kriterie fra Artikel 29-gruppens retningslinjer (WP248 rev. 01).
5. Behandling der fører til afgørelser om en fysisk persons rettigheder til et produkt, en service, en potentiel mulighed eller begunstigelse, der er baseret på en hvilken som helst form for automatiseret afgørelse (herunder profilering)
6. Behandling der omfatter profilering af fysiske personer i stor skala, sådan som dette er defineret i Artikel 29-gruppens retningslinjer (WP248 rev. 01).
7. Behandling af personoplysninger om sårbare personer eller hvor der er tale om behandling af følsomme oplysninger (særlige kategorier) og hvor, der benyttes profilering eller andre former for automatiserede afgørelser.
8. Behandlinger hvor et brud på persondatasikkerheden kan have en direkte effekt på en persons fysiske helbred eller på sikkerheden for en fysisk person.

WP 29 Guidelines – 10 criteria



Evaluation and
scoring



Automated decision
making with legal or
similar significant
effect



Systematic
monitoring



Sensitive data



Large scale



Matching or
combining datasets



Data of vulnerable
subjects



Use of
new/innovative
solutions



Data transfers
across borders
outside the EU*



Processing preventing
individuals from
exercising a right/using
a service/contract

Hvad skal DPIA omfatte?

1. Systematisk beskrivelse af behandlingsaktiviteter/formål (GDPR art. 35, stk. 7, nr. 1)

- Ansvarsfordeling
- Formål og retsgrundlag med behandlingen
- Omfang af behandlingsaktiviteter
- Kortlægning af datastrømme
- Funktionel beskrivelse af behandlingen
- Beskrivelse af aktiviteter, som behandlingen er afhængig af

2. Er behandlingsaktiviteterne nødvendige og står de i rimeligt forhold til formålene (GDPR art. 35, stk. 7, nr. 2)

- Principperne i art. 5

3. Vurdering af risiciene for de berørte borgeres rettigheder og frihedsrettigheder (GDPR art. 35, stk. 7, nr. 3)

- Risikovurdering

4. Mitigerende foranstaltninger (GDPR art. 35, stk. 7, nr. 4)

- garantier, sikkerhedsforanstaltninger og –mekanismer

Konsekvensanalyser - eksempler

Ekspertter dumper håndtering af datasikkerhed i giga forskningsprojekt med sygehusjournaler

Region Hovedstaden har ikke levet op til lovkrav, der skal beskytte følsomme persondata, vurderer flere eksperter.

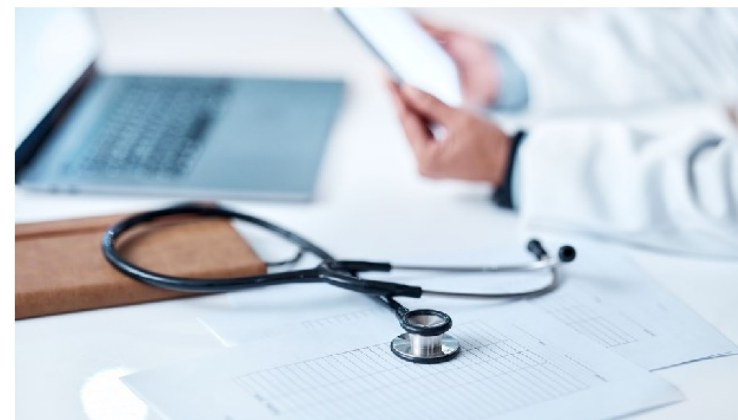


Datatilsynet indleder undersøgelse af Region Hovedstaden

Dato: 08-09-2025

Nyhed

Region Hovedstaden har i den forgangne uge fået medieomtale for sin behandling af personoplysninger i et forskningsprojekt. Datatilsynet har nu indledt en undersøgelse af behandlingen og har i den forbindelse bedt Region Hovedstaden om en redegørelse.



Den 5. september 2025 har Datatilsynet indledt en sag af egen drift af et konkret forskningsprojekt i Region Hovedstaden. Det sker på baggrund af den medieomtale, der har været i DR i sidste uge.

Datatilsynet har bl.a. bedt Region Hovedstaden om en redegørelse for de databeskyttelsesretlige vurderinger, der er blevet foretaget, inden påbegyndelse af behandling af personoplysninger i det pågældende projekt.

Konsekvensanalyser

- case

- ▶ Hvorfor må superligaen anvende ansigtsgenkendelse?
- ▶ Hvad er behandlingsgrundlaget?
- ▶ Hvad er betingelserne?
- ▶ <https://www.datatilsynet.dk/afgoerelser/afgoerelser/2025/jul/-fodboldklubberne-i-superligaen-faar-tilladelse-til-brug-af-ansigtsgenkendelse>



Sikkerhedsbrud
art. 33 og 34

Hvornår er der tale om et sikkerhedsbrud?

- Art. 4, nr. 12) »brud på persondatasikkerheden«: et brud på sikkerheden, der fører til hændelig eller ulovlig tilintetgørelse, tab, ændring, uautoriseret videregivelse af eller adgang til personoplysninger, der er transmitteret, opbevaret eller på anden måde behandlet



Hvad er et sikkerhedsbrud?



De 10 typiske brud

10 typiske brud

1 ›

Data til forkerte modtagere fordi forkert adressat flettes ind i udgående post

2 ›

Beskyttet adresse eksponeres fejlagtigt efter ændring i it-system

3 ›

Fejludlevering af data ved sagsbehandling

4 ›

Manglende sletning af data ved brug af digitale værktøjer

5 ›

Auto-complete medfører, at e-mails bliver sendt til forkerte modtagere

6 ›

Tab/tyveri af transportable enheder med ukrypteret data

7 ›

For bred adgang til data på netværksdrev mv.

8 ›

Uautoriseret adgang til data grundet dårligt design, kodefejl og utilstrækkelige tests

9 ›

Videregivelse af data gemt i skabelon-

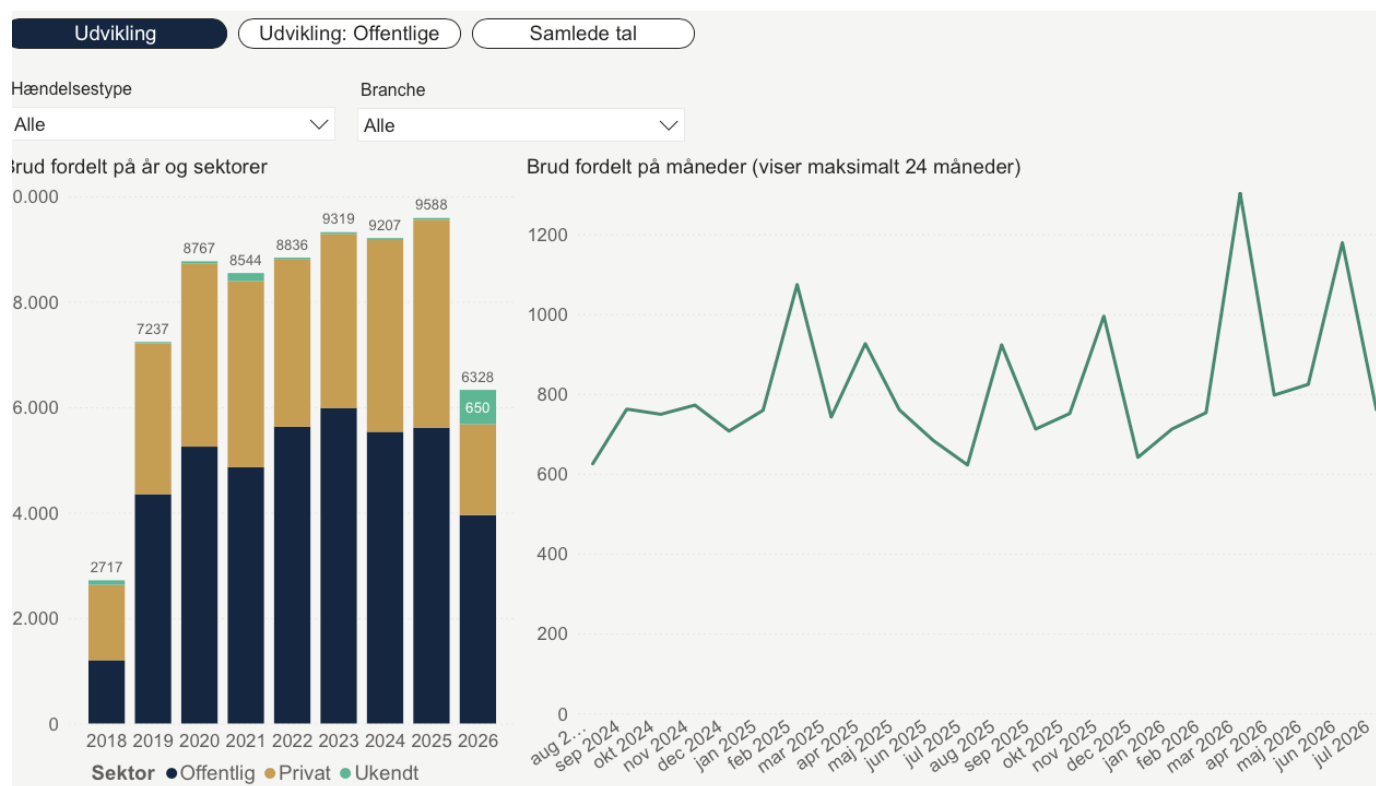
10 ›

Ondsindet software (ransomware).

OPBYGNING

Statistik over brud

32



To pligter for DA ved sikkerhedsbrud

33

Anmeldelse af brud til DT

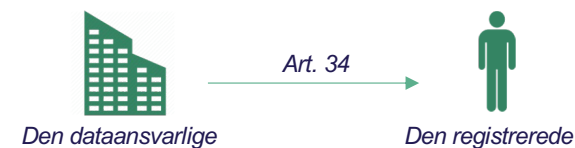


- HR: Skal anmeldes
U1: Usandsynligt, at bruddet indebærer en risiko for de registrerede.
DA bevisbyrde



- "Uden unødigt forsinkelse og om muligt senest 72 timer"
• Tidspunkt: DA bekendt med brud

Underretning om brud til registrerede



- HR: "Høj risiko" for den registrerede
U1: Usandsynligt, at bruddet indebærer en høj risiko for de registrerede. f.eks. pga. kryptering.
U2: Uforholdsmæssig stor indsats for DA – i stedet offentlig meddelelse



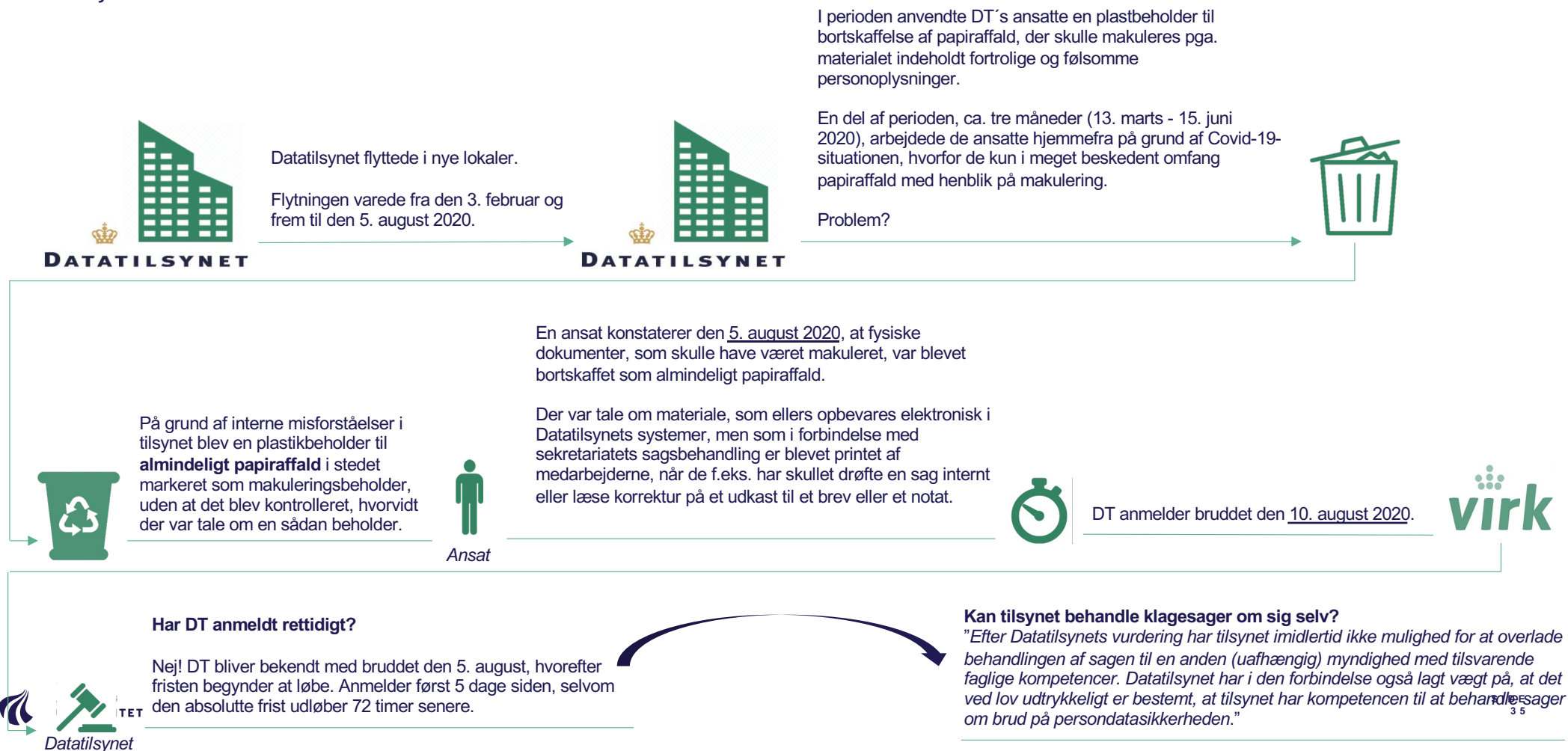
- DA bevisbyrde
"Uden unødigt forsinkelse"
• Tidspunkt: DA bekendt med brud

Alle sikkerhedsbrud skal dokumenteres (intern log)

- Faktiske omstændigheder ved bruddet:
 - Bruddets karakter
 - Antal berørte registrerede
 - Typer af personoplysninger
 - Bruddets varighed start og ophør
- Vurdering af konsekvenserne forbundet med bruddet
- Eventuelle afhjælpende foranstaltninger truffet
- Om bruddet er anmeldt til Datatilsynet og om de berørte registrerede er underrettet

Anmeldelse til DT

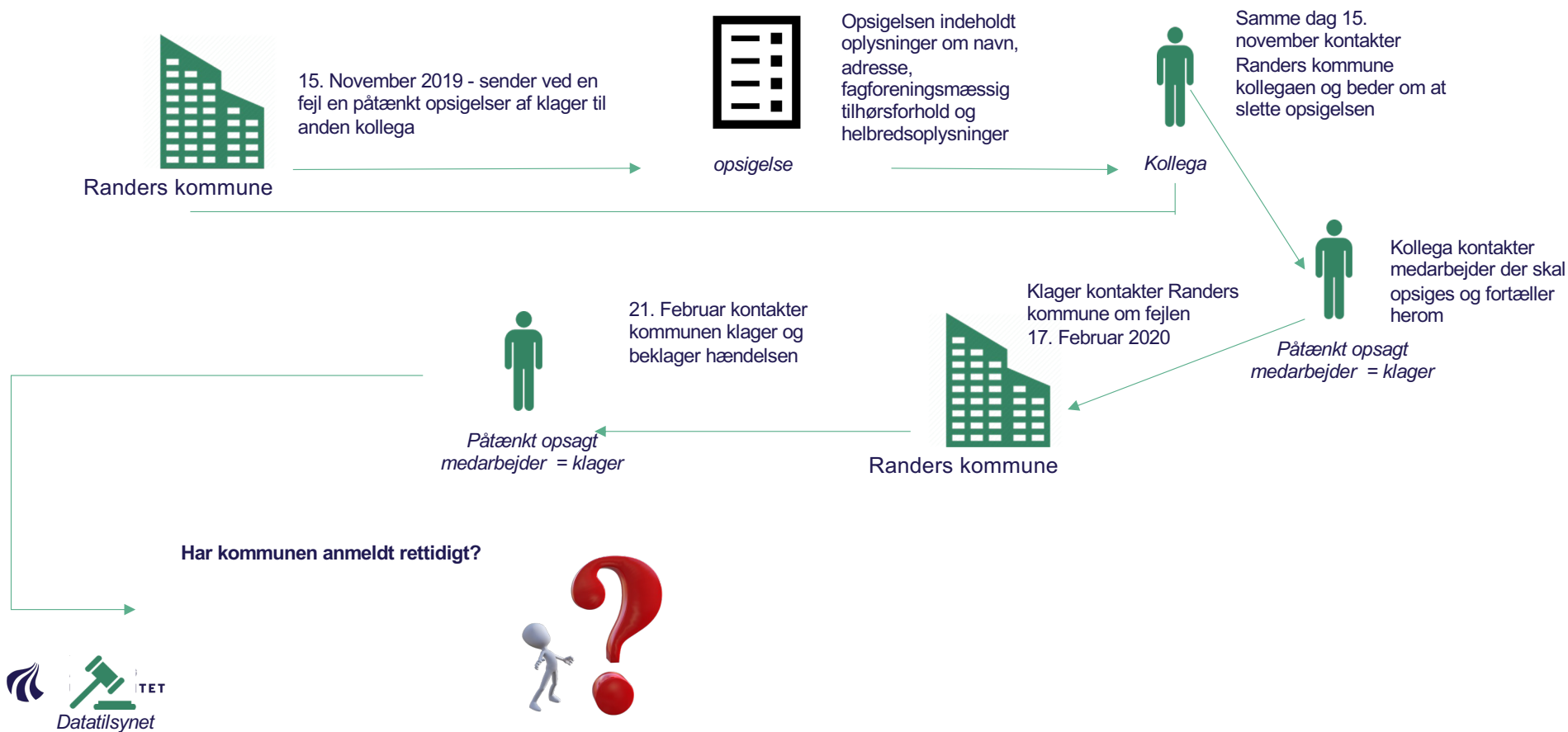
DT j.nr. 2020-442-8866



Anmeldelse til DT

DT j.nr. 2020-32-1390

36



Databeskyttelsesrådgiver (DPO)
art. 37-43

Databeskyttelsesrådgiver

GDPR art. 37-43

- ▶ Databeskyttelsesrådgiverens funktion er at understøtte, at den dataansvarlige overholder reglerne i databeskyttelsesforordningen
- ▶ Det er den dataansvarlige, der har *ansvaret* for at sikre, at databeskyttelsesforordningen og databeskyttelseslovens regler overholdes.
- ▶ Den dataansvarlige udpeger databeskyttelsesrådgiveren.
- ▶ Det er databeskyttelsesrådgiverens opgave at *rådgive* den dataansvarlige om de databeskyttelsesretlige regler, og rådgiveren kan således på bedste vis understøtte en god databeskyttelse hos den dataansvarlige.



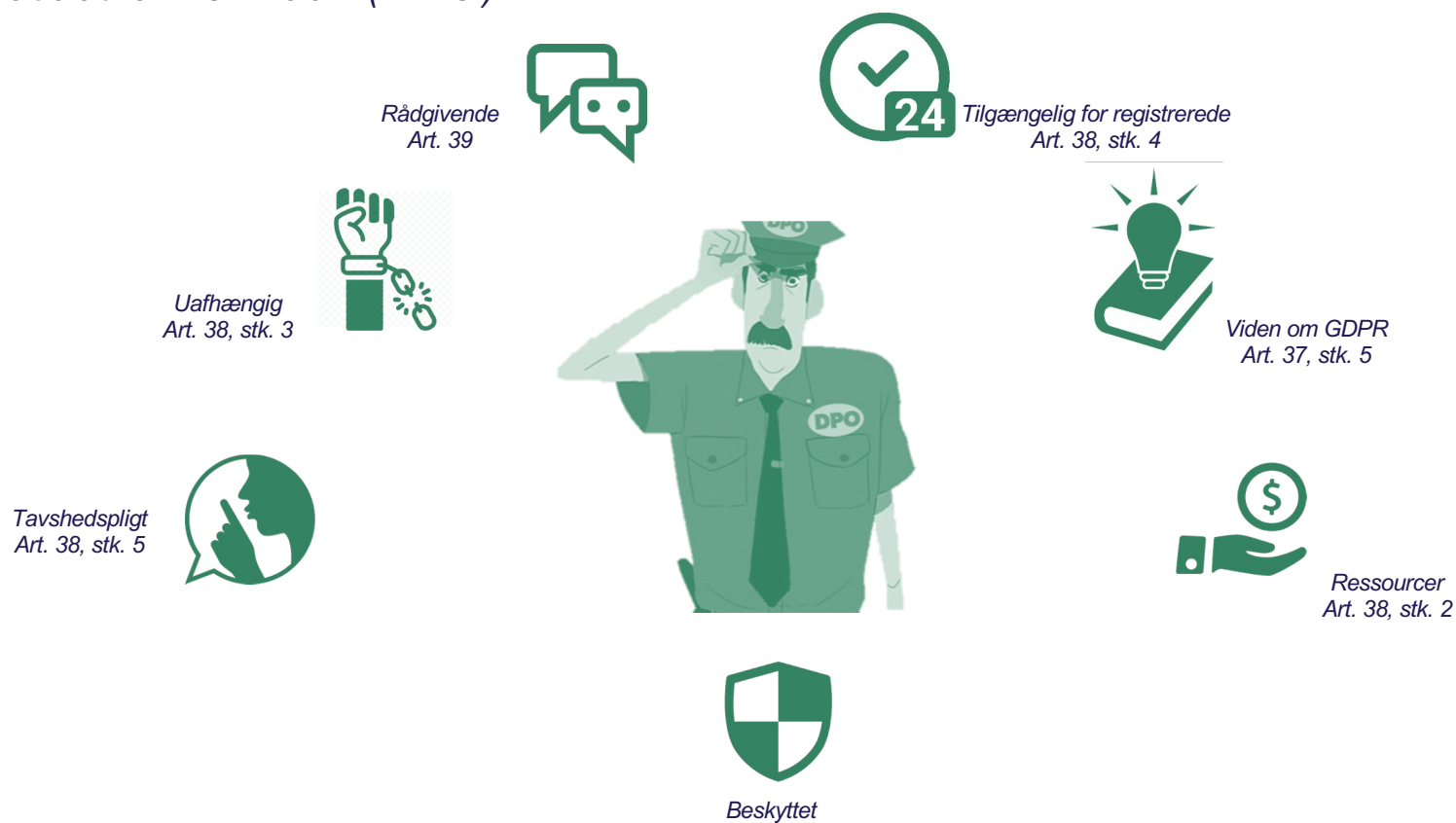
Dataansvarlig
- Har ansvaret



DPO rådgiver

Databeskyttelsesrådgiver

Data Protection Officer (DPO)



Udpegelse af DPO

40



Frivillig udpegelse af DPO (GDPR art. 37, stk. 4)

- DPOén omfattes af GDPR art. 37-39

Fejltagtig udpegelse af DPO

- DPOén omfattes af GDPR art. 37-39

Obligatorisk udpegelse af DPO

- DPOén omfattes af GDPR art. 37-39

Hvem er forpligtet til at udpege en DPO (GDPR art. 37, stk. 1, litra a-c)

Offentlig sektor (litra a):

Pligt for offentlige myndigheder og organer

Uanset om de er dataansvarlige eller databehandlere

Hvornår er man en offentlig myndighed? Forvaltningslovens § 1, stk. 1-2

Privat sektor (litra b-c):

Tre kumulative betingelser;

- 1) skal være virksomhedens kerneaktivitet og
- 2) der skal behandles personoplysninger i et stort omfang, og
- 3) behandlingsaktiviteten skal bestå i regelmæssig og systematisk overvågning af personer, eller behandlingen skal vedrøre følsomme oplysninger eller oplysninger om strafbare forhold.

Case: DPO og fortegnelse

Advokatfirma X behandler store mængder personoplysninger som led i sine aktiviteter. Virksomheden har i flere år haft en databeskyttelsesrådgiver (DPO), men ledelsen beslutter at nedlægge funktionen med den begrundelse, at virksomheden ikke mener at være omfattet af pligten til at udpege en DPO efter GDPR artikel 37.

Beslutningen dokumenteres ikke nærmere. Samtidig viser det sig, at virksomheden ikke har klare procedurer for DPO'ens rolle, uafhængighed eller rapportering til den øverste ledelse. Virksomhedens hjemmeside indeholder heller ikke opdaterede kontaktoplysninger på DPO'en.

Under et tilsyn konstateres det desuden, at virksomhedens fortegnelse over behandlingsaktiviteter ikke afspejler alle de behandlinger, som virksomheden faktisk udfører, herunder visse aktiviteter, der udføres på vegne af klienter.

Datatilsynet skal nu tage stilling til, om virksomheden lever op til GDPR's krav om udpegelse af DPO, organiseringen af DPO-funktionen og dokumentation af behandlingsaktiviteter.

Spørgsmål

1. Hvornår er en virksomhed forpligtet til at udpege en DPO efter GDPR artikel 37?
2. Hvilken betydning har det, hvis en virksomhed frivilligt har udpeget en DPO?
3. Hvilke krav stiller GDPR til DPO'ens rolle, uafhængighed og adgang til ledelsen?
4. Hvilke krav gælder for offentliggørelse af DPO'ens kontaktoplysninger?
5. Hvilke krav stilles der til en fortegnelse over behandlingsaktiviteter?
6. Hvilken betydning har mangelfuld dokumentation for virksomhedens overholdelse af GDPR?

Se [https://gdprhub.eu/index.php?title=Datatilsynet_\(Norway\)_-_21/03823-45](https://gdprhub.eu/index.php?title=Datatilsynet_(Norway)_-_21/03823-45)

Datatilsynet

Artikel 51 & 54

43

Artikel 51 Tilsynsmyndighed

1. Hver medlemsstat sikrer, at en eller flere uafhængige offentlige myndigheder er ansvarlige for at føre tilsyn med anvendelsen af denne forordning, for at beskytte fysiske personers grundlæggende rettigheder og frihedsrettigheder i forbindelse med behandling og for at lette fri udveksling af personoplysninger i Unionen (»tilsynsmyndighed«).
2. Hver enkelt tilsynsmyndighed bidrager til ensartet anvendelse af denne forordning i hele Unionen. Til dette formål samarbejder tilsynsmyndighederne med hinanden og med Kommissionen i henhold til kapitel VII.

Hver medlemsstat kan oprette et eller flere nationale myndigheder, der er tilsynsansvarlige.

- Tyskland → 16 lokale Datatilsyn for den private sektor
- Danmark
 - Domstolsstyrelsen, der fører datatilsyn med domstolenes administrative funktioner (DBL § 37, stk. 2 + GDPR art. 55, stk. 3)
 - Datatilsynet varetager de EU-orienterede opgaver.



Regler om oprette af en tilsynsmyndighed → Art. 54

- Tilsynet skal oprettes ved lov, der skal rumme litra a-f. (GDPR art. 54, stk. 1)
- Tilsynsmyndighedens medlemmer og personsale har tavshedspligt. (GDPR art. 54, stk. 2)

Datenschutzaufsichtsbehörden für den nicht-öffentlichen Bereich

Baden-Württemberg

Der Landesbeauftragte für den Datenschutz Baden-Württemberg

Bayern

Landesamt für Datenschutzaufsicht

Berlin

Berliner Beauftragter für Datenschutz und Informationsfreiheit

Brandenburg

Die Landesbeauftragte für den Datenschutz und für das Recht auf Akteneinsicht Brandenburg

Bremen

Die Landesbeauftragte für Datenschutz und Informationsfreiheit Bremen

Hamburg

Der Hamburgische Beauftragte für Datenschutz und Informationsfreiheit

Hessen

Der Hessische Datenschutzbeauftragte

Mecklenburg-Vorpommern

Der Landesbeauftragte für Datenschutz und Informationsfreiheit Mecklenburg-Vorpommern

Niedersachsen

Die Landesbeauftragte für den Datenschutz Niedersachsen

Rheinland-Pfalz

Der Landesbeauftragte für den Datenschutz und die Informationsfreiheit Rheinland-Pfalz

Saarland

Unabhängiges Datenschutzzentrum

Sachsen

Der Sächsische Datenschutzbeauftragte

Sachsen-Anhalt

Landesbeauftragter für den Datenschutz Sachsen-Anhalt

Schleswig-Holstein

Unabhängiges Landeszentrum für Datenschutz Schleswig-Holstein

Thüringen

Der Thüringer Landesbeauftragte für den Datenschutz und die Informationsfreiheit

Artikel 52

1. Fuld Uafhængighed

- Tilsynsmyndigheder skal udføre deres opgaver og udøve deres beføjelser i fuld uafhængighed

2. Fri for Udefrakommende Indflydelse

- Medlemmerne af tilsynsmyndighederne må ikke søge eller modtage instrukser fra andre og skal være frie for direkte eller indirekte indflydelse

3. Uforenelig Virksomhed

- Medlemmerne skal afholde sig fra handlinger, der er uforenelige med deres hverv, og må ikke udøve uforenelig lønnet eller ulønnet virksomhed

4. Ressourcer og Infrastruktur

- Nødvendige Ressourcer: Medlemsstaterne skal sikre, at tilsynsmyndighederne har de nødvendige menneskelige, tekniske og finansielle ressourcer samt lokaler og infrastruktur til effektivt at kunne udføre deres opgaver

5. Eget Personale

- Valg af Personale: Tilsynsmyndighederne skal vælge og råde over deres eget personale, som alene er under ledelse af myndighedens medlemmer

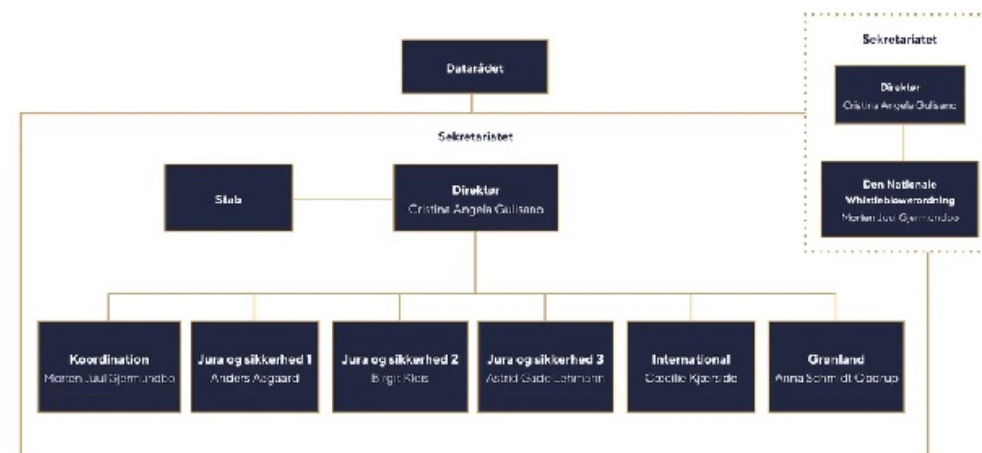
6. Finansiell Kontrol

- Uafhængig Finansiell Kontrol: Tilsynsmyndighederne skal være underlagt finansiell kontrol, som ikke påvirker deres uafhængighed, og de skal føre særskilte, offentlige årsbudgette

Datatilsynet

Organisation

- ▶ Datatilsynet er en uafhængig tilsynsmyndighed, som har ansvaret for, at reglerne om databeskyttelse bliver overholdt.
- ▶ Datatilsynet rådgiver og vejleder, behandler klager og gennemfører tilsyn hos myndigheder og virksomheder.
- ▶ Datatilsynets lovbestemte beføjelser, funktioner og pligter stammer fra databeskyttelsesforordningen, databeskyttelsesloven, retshåndhævelsesdirektivet, retshåndhævelsesloven samt tv-overvågningsloven.



Art. 57 Datatilsynets opgaver

46

1. Tilsyn og Håndhævelse	Tilsynsmyndighederne skal føre tilsyn med og håndhæve anvendelsen af GDPR
2. Offentlig Bevidsthed	Fremme offentlighedens kendskab til og forståelse af risici, regler, garantier og rettigheder i forbindelse med databehandling
3. Rådgivning	Rådgive nationale parlamenter, regeringer og andre institutioner om lovgivningsmæssige og administrative foranstaltninger til beskyttelse af personers rettigheder og friheder
4. Information til Registrerede	Informere registrerede om udøvelse af deres rettigheder og samarbejde med andre tilsynsmyndigheder, hvis relevant
5. Klagebehandling	Behandle klager fra registrerede og undersøge genstanden for klagen
6. Samarbejde	Samarbejde med andre tilsynsmyndigheder, herunder udveksling af oplysninger og gensidig bistand
8. Overvågning af Udvikling	Holde øje med relevant udvikling, især inden for informations- og kommunikationsteknologi
10. Konsekvensanalyse	Opstille og føre en liste over krav til konsekvensanalyse vedrørende databeskyttelse



Datatilsynet

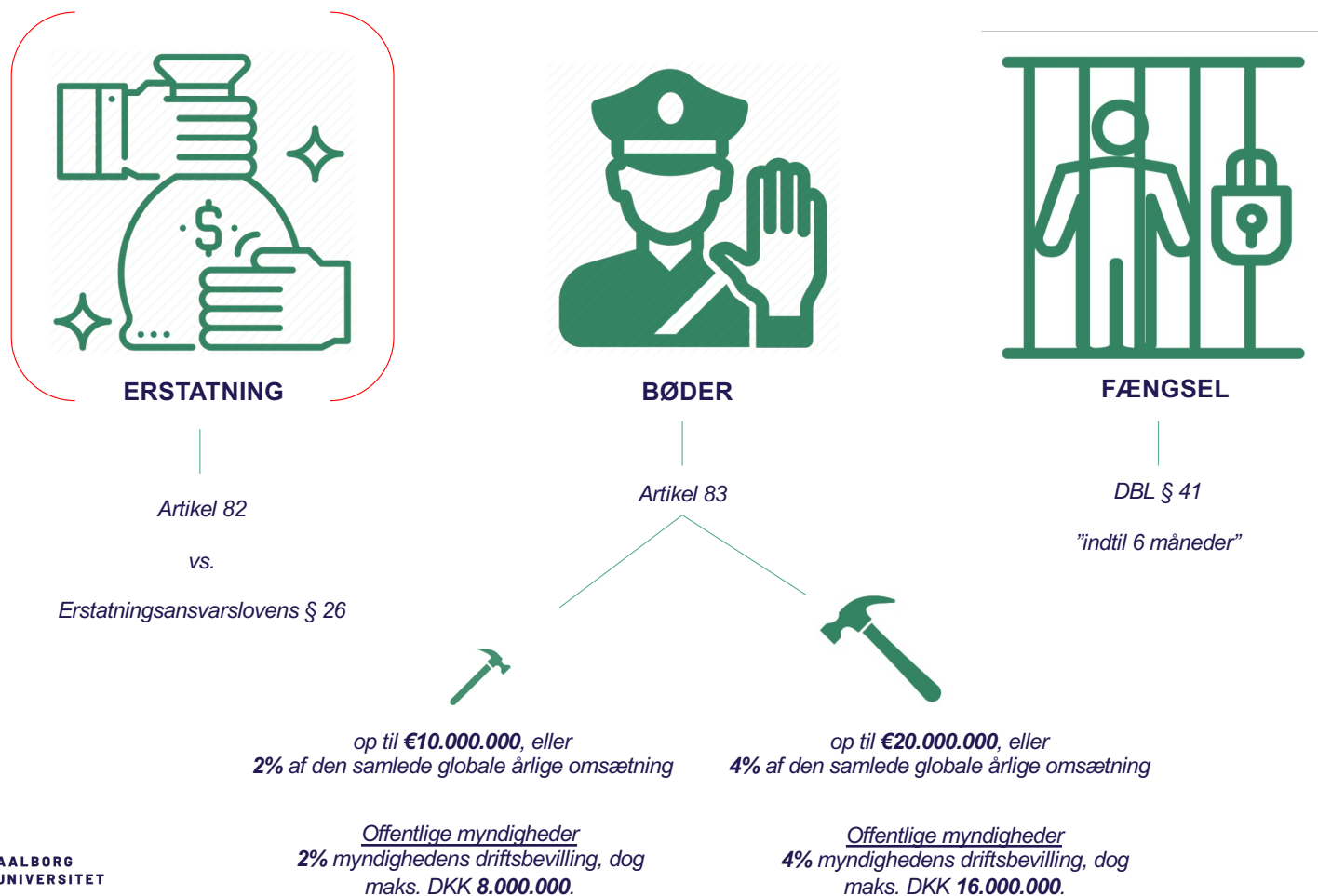
Kompetence

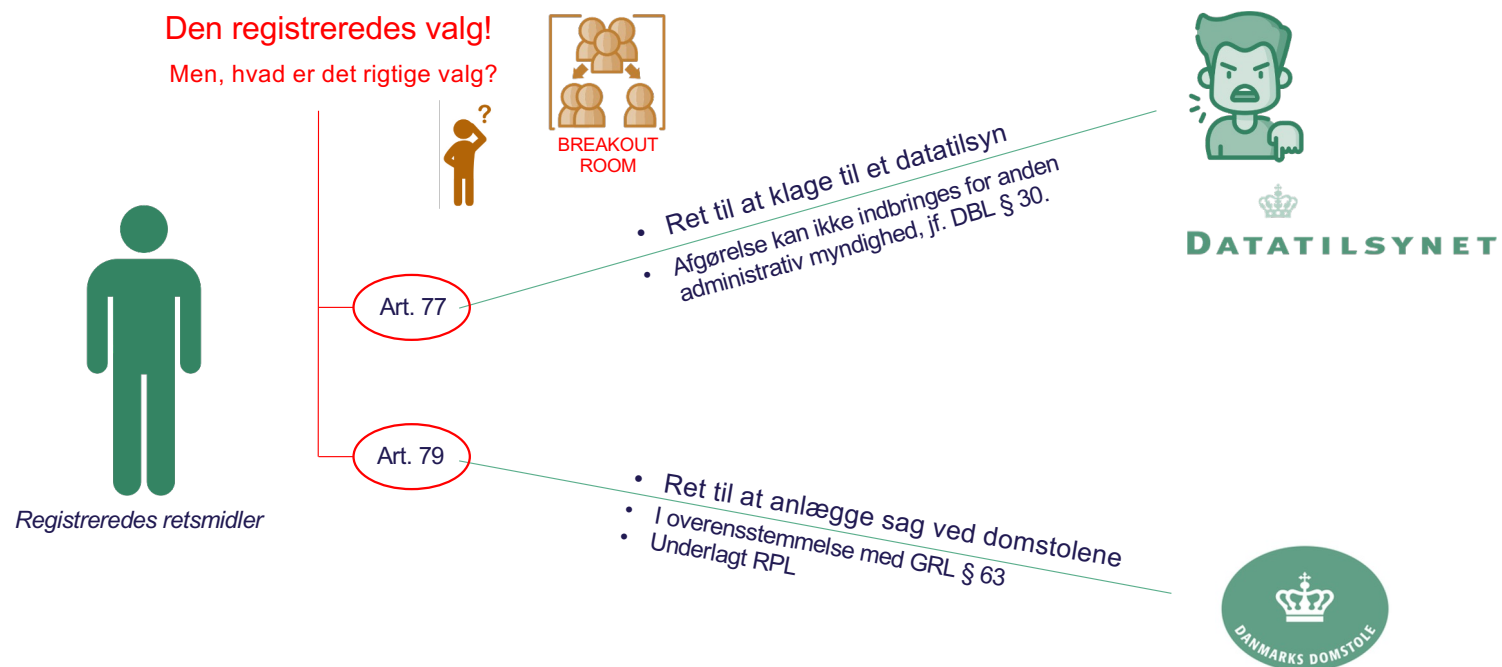
Artikel 58 og præambel, betragtning 129:

- Undersøgelsesbeføjelser, se Artikel 58, stk.1, og DBL § 29, stk. 2.
- Korrigerende beføjelser som advarsler, kritik, påbud mv., se Artikel 58, stk. 2.
 - Art, 58, stk. 2, litra b ”at udtale kritik af en dataansvarlig eller en databehandler, hvis behandlingsaktiviteter har været i strid med denne forordning ”
- Godkendelses- og rådgivningsbeføjelser, jf. Artikel 58, stk. 3.
- Overtrædelser kan indbringes for domstolene, jf. Artikel 58, stk. 5, og DBL § 30, stk. 2.

Sanktioner

48





PRO

1. Opstart af klagesag alene betinget af den registreredes subjektive opfattelse af 'krænkelsen',
2. Officialmaksimen,
3. Vederlagsfri klagesagsbehandling, jf. art. 57 (3),
4. Relativ hurtig sagsbehandling,
5. Enkeltinstansafgørelse
6. Mulighed for sanktionering (skal efterfølgende føres af Anklagemyndigheden).

CON

1. Ingen mulighed for tildeling af compensation el. erstatning,
2. Afgørelsen kan efterfølgende indbringes for Domstolene.
3. Hvis repræsentant (f.eks. advokat) er det uforholdsmæssigt dyrt pga. ingen tildeling af sagsomkostninger.

CON

1. Opstart betinget af forudgående dialog ang. forligsmæssig løsning, jf. RPL § 336 a,
2. Forhandlingsprincippet,
3. Risiko for idømmelse af sagsomkostninger, jf. RPL kap. 30,
4. Lang sagsbehandlingstid,
5. To instans princippet,
6. Ikke mulighed for sanktion (bøde m.v.)

PRO

1. Mulighed for tildeling af compensation el. erstatning,
2. Mulighed for retshjælp // fri proces, jf. RPL § 325-329.
3. Hovedforhandling, herunder udvidet mulighed for bevisførelse, f.eks. partsforklaring, syn og skøn m.v.

Klager ved DT 2025

- Hvad sker der, når DT får en klage?
Konsekvenser mv.
- <https://www.datatilsynet.dk/borger/klage/behandling-af-klagesager>



Dansk bødeniveau

Administrative bøder ??

53

Danmark

- Bøder er **altid** en strafferetlig reaktion

Præambel, betragtning nr. 151: "... *Reglerne om administrative bøder kan i Danmark anvendes ved, at bøder pålægges af de kompetente nationale domstole som en strafferetlig sanktion...*"

- **DBL § 42:** Sagen kan afgøres uden retssag, hvis den, der har begået overtrædelsen, erklærer sig skyldig og vil betale bøden!
- Momenter ved fastsættelse af en bøde:
En række momenter bør tages i betragtning, jf. Artikel 83, stk. 2, litra a-k, blandt andet:

Overtrædelsens karakter, antal registrerede, om den blev begået forsætligt eller uagtsomt, om der er gjort noget for at begrænse skaden, om det er sket før, hvilke typer persondata, der er tale om (herunder om oplysningerne er identificerede eller identificerbare), og om et tilsluttet adfærdskodeks eller certificeringsmekanisme er blevet overholdt.

- Bøden skal være effektiv, proportional og afskrækkende, jf. Artikel 83, stk. 1

Link til bødesager: <https://www.datatilsynet.dk/afgoerelser/boedesager>

IDesign

54

Sagens omstændigheder:

- Kundeoplysninger (navn, adresse, tlf.nr., mail og købshistorik for ca. 385.000 personer.
- Opbevaret i et gammelt ERP-system (AX 2.5).
- Mere end 5 år gamle.
- Ingen sletning, ej heller slettepolitik.
- Datatilsynet politiindstiller til DKK 1,5 mio.

Byretten i Aarhus:

- Anklagemyndighedens påstand: DKK 1,5 mio.
- Retten: Det objektive og subjektive gerningsindhold er opfyldt.
- Ad bødeudmåling: Retten finder bødeudmåling ikke skal ske på baggrund af koncernens omsætning og en række formildende omstændigheder gør sig gældende.
- Nedsættelse af bøden til DKK 100.000.

Vestre Landsret:

- Hovedforhandling den 17.-19. januar 2022.
- Anklagemyndigheden anmoder den 14. januar 2022 om udsættelse af sagen med henblik på belysning af sagens tvist vedr. forståelsen af "virksomhed" skal præjudicielt forelægges EU-domstolen.
- Vestre Landsret udsætter sagen samme dag.
- Sagen er 30. november 2022 forelagt EU-Domstolen.
- 2. september 2025 Vestre Landsret idømmer bøde på 1,5 mio. kr.

Arp-Hansen

55

Sagens omstændigheder:

- Kundeprofiler (navn, adresse, tlf.nr., mail og købshistorik for ca. 500.000 personer).
- Opbevaret i Arp-Hansens bookingsystem.
- Aftalt automatisk sletning med leverandøren af bookingsystemet, som ikke blev overholdt.
- Slettepolitik, der fastsat kortere slettefrister end dansk lovgivning (180 og 380 dage).
- Straks manuel sletning ved viden herom.
- GDPR var netop trådt i kraft på tidspunktet for tilsynsbesøget.
- Datatilsynet politiindstiller til DKK 1,1 mio.

Retten i Lyngby:

- Datatilsynet indstiller efterfølgende til, at bøden skal udmåles til DKK 350.000 pga. Arp-Hansen er på grænsen til kategorien "stor virksomhed" ift. bødevejledningen.
- Retten finder, at det objektive og subjektive gerningsindhold er opfyldt.
- I forhold til bødeudmåling finder rettens flertal, at Arp-Hansen skal tildes en advarsel, mindretallet finder, at Arp-Hansen skal pålægges en bøde på DKK 175.000.
- Formildende omstændighed er blandt andet sagsbehandlingstiden på mere end 3 år.

Vestre Landsret

20. September 2023 bøde på 1 mio. kr.

Bøder

56

40

bødeindstillinger efter GDPR

[Se en oversigt over bødesager](#)

20.536

nyoprettede sager i 2025

[Se mere i årsrapporten](#)

Det Europæiske Databeskyttelsesråd

57

- EDPB har afløst den tidligere Artikel 29-Gruppe.
- Reguleres i GDPR Artikel 68-76.
- Sammensættes af repræsentanter fra medlemsstaternes tilsynsmyndigheder.
- Skal sikre ensartet anvendelse af GDPR.
- Rådets væsentligste opgaver:
 - Udstede vejledninger om forståelsen af reglerne i GDPR .
 - Træffe afgørelser om generelle spørgsmål .
 - Træffe bindende afgørelser i konkrete sager, hvor flere involverede tilsyn ikke er enige om, hvad der skal være sagens resultat.



Hvad har vi lært

Case: BorgerPuls

Nordby Kommune lancerer BorgerPuls, en app, der samler navn, CPR-nr., lokation, helbredsoplysninger og adfærdsmønstre for at målrette tilbud til borgerne.

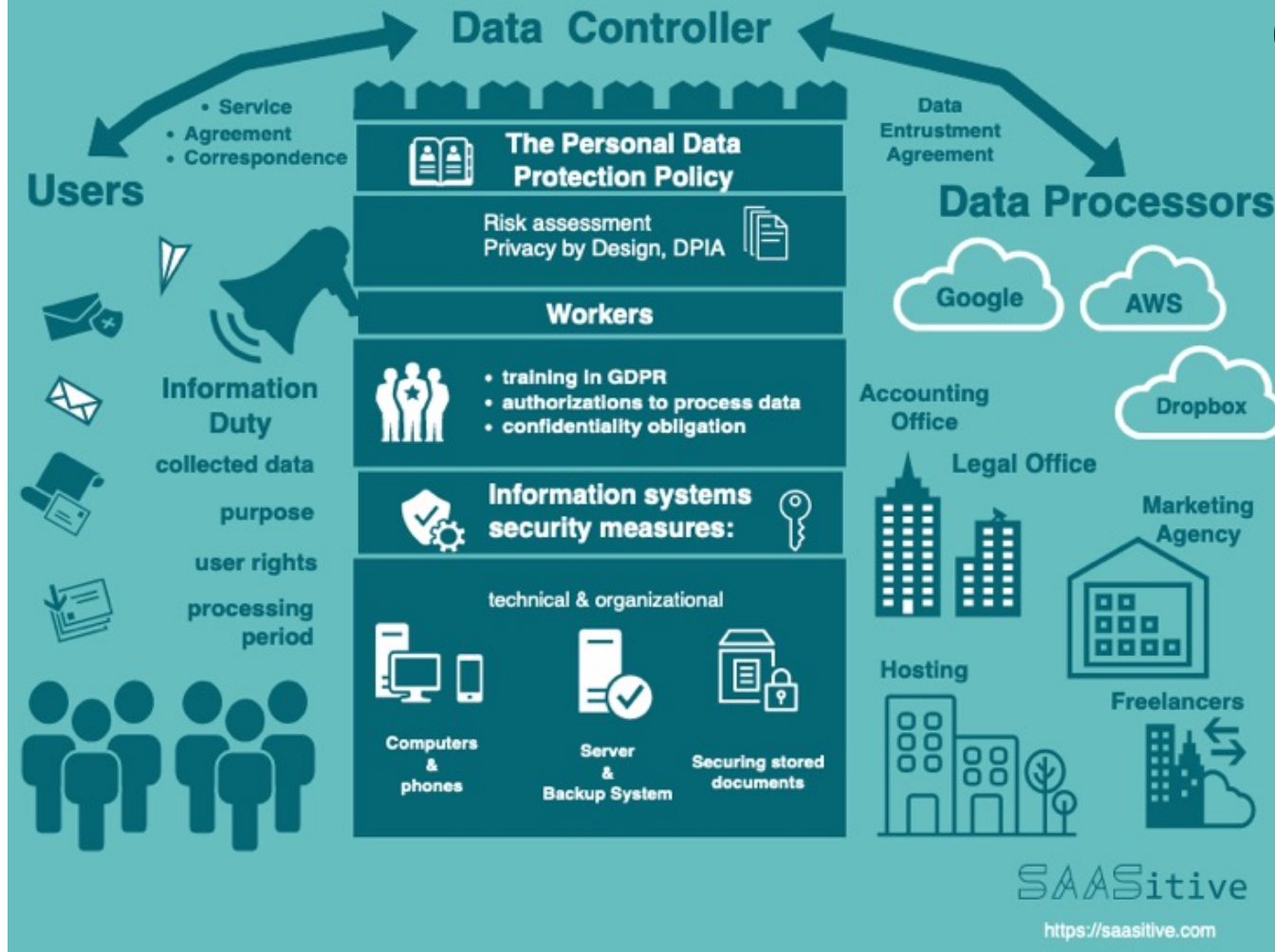
Leverandøren bruger en ny AI-model og underdatabehandlere uden for EU. Ved lanceringen er fortegnelsen ikke opdateret, standardindstillinger deler lokation bredt, slettefrister er ikke fastlagt, og ledelsen har hverken dokumenteret risikovurdering eller DPIA. DPO'en blev først orienteret kort før lanceringen og refererer til IT-chefen.

Tre måneder senere giver en fejl i adgangsstyringen uvedkommende adgang til 4.000 borgerprofiler i 36 timer. Kommunen lukker adgangen, men venter fire døgn med at anmelde bruddet. En borger klager til Datatilsynet og kræver erstatning.

JERES OPGAVE · RÅDGIV LEDELSEN

- 1 FORTEGNELSE** Hvad skal registreres og dokumenteres?
- 2 DESIGN & DEFAULT** Hvilke data, adgange, slettefrister og standardindstillinger skal ændres – set i lyset af det aktuelle tekniske niveau og omkostningerne?
- 3 SIKKERHED** Hvilke risici og passende tekniske og organisatoriske foranstaltninger skal vurderes?
- 4 DPIA** Hvilke analyser skal gennemføres, og hvornår?
- 5 SIKKERHEDSBRUD** Hvilke pligter følger af artikel 33 og 34 – inklusive den interne log?
- 6 DPO** Er DPO'ens placering, uafhængighed og involvering forsvarlig?
- 7 TILSYN & RETSMIDLER** Hvad kan Datatilsynet gøre, hvilke sanktioner er relevante, og hvilke muligheder har borgeren?

GDPR EXPLAINED



Og meget mere!!!